

Enterprise AI Authentication Research • Part 5 of 7

Part 5

Marketplace Connectors & Enterprise Architecture Patterns

Marketplace OAuth models, consent flows, token lifecycle, and reference architectures from Microsoft, Google, AWS, Atlassian

Enterprise Authentication & Identity Propagation for AI Agents

Marketplace Connectors

Enterprise AI platforms extend their capabilities through marketplace connectors — pre-built integrations distributed through GitHub Marketplace, Atlassian Marketplace, ServiceNow Store, Microsoft AppSource, Google Workspace Marketplace, and AWS Marketplace. Each marketplace has a distinct OAuth consent, permissions, and token management model.

GitHub Marketplace

GitHub Marketplace distributes GitHub Apps and OAuth Apps. GitHub Apps are the preferred model: they are installed at the organization level by an admin, use installation tokens (not user credentials), and support fine-grained repository permissions.

GitHub Marketplace — App Lifecycle

Lifecycle Stage	GitHub App Model	OAuth App Model
Initial consent	Org admin installs via Marketplace; selects repos + permissions	User OAuth consent per user; no org admin requirement
Admin consent	Required for org-level installation	Optional (owner can pre-approve)
OAuth authorization	Installation token via JWT exchange (no user OAuth required)	User-level OAuth consent per user per app
Refresh token	No refresh token — JWT → installation token every 1 hour	Refresh token stored per user; long-lived
Long-lived credentials	Private key for JWT signing (rotate regularly)	OAuth token until revoked
Permissions update	Admin must re-approve if app requests new permissions	User must re-consent if scopes expand
Revocation	Admin uninstalls app; all installation tokens immediately invalid	User or admin revokes; OAuth token invalidated
Token rotation	Automatic — 1-hour installation tokens	Manual rotation or revocation only

Atlassian Marketplace

Atlassian Marketplace apps are distributed as Connect apps (cloud), Forge apps (cloud, serverless), or DC/Server apps. Forge is the recommended model for new apps: it runs in Atlassian's serverless infrastructure and uses OAuth 2.0 3LO with declarative scopes in the manifest.yml.

Atlassian Marketplace — Consent & Token Models

Consent Type	Forge App	Connect App	DC/Server App
User consent	OAuth 2.0 consent per user (3LO)	OAuth 2.0 consent per user	Admin-configured, user trust implied
Admin consent	Site admin approves app installation	Site admin approves + configures	Admin installs; org-level consent
OAuth flow	3LO (auth code + PKCE)	3LO (auth code)	Not OAuth — uses JWT lifecycle
Refresh token	Managed by Atlassian platform	App must manage refresh token	App manages session
Permissions update	Manifest change → admin re-approves	App descriptor update → re-consent	Admin re-installs
Revocation	Site admin uninstalls; tokens revoked	Admin revokes; tokens revoked	Admin removes app
Token rotation	Platform-managed	App-managed via OAuth refresh	Session-based rotation

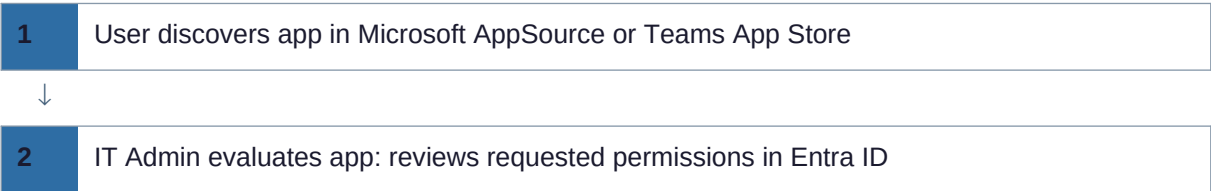
Microsoft AppSource

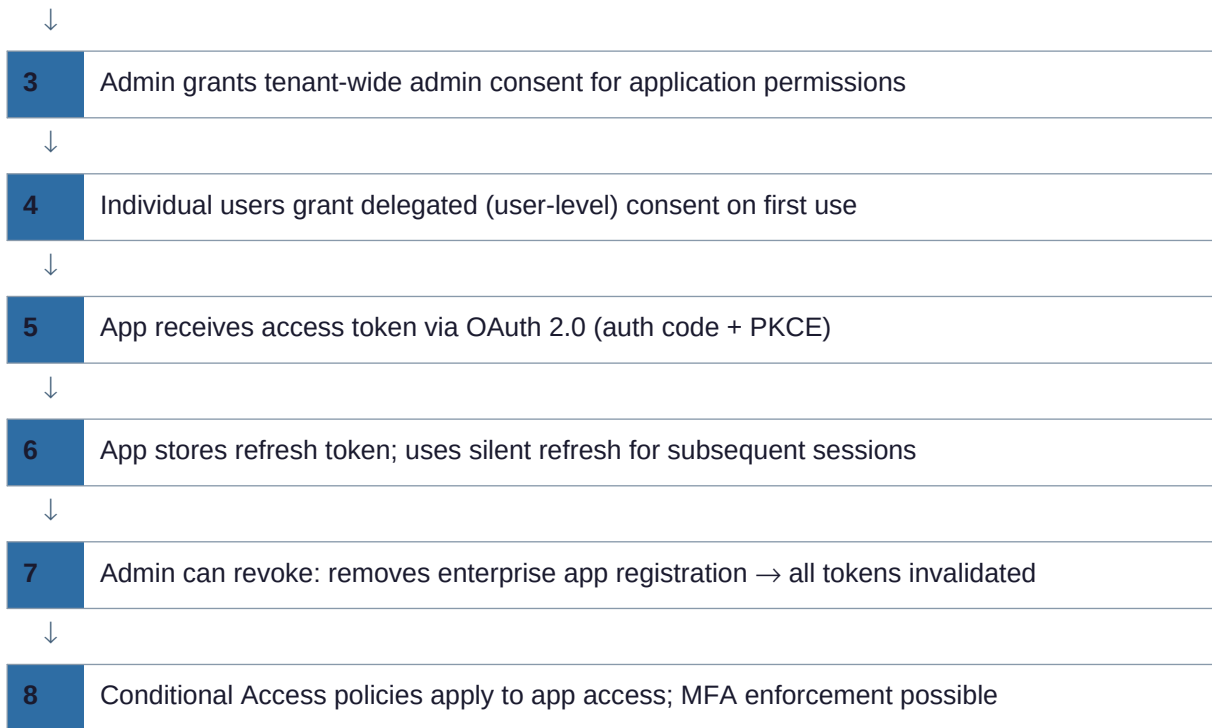
Microsoft AppSource distributes Teams apps, Power Platform connectors, Copilot extensions, and Azure integrations. The consent model leverages Microsoft Entra ID admin consent for tenant-wide permissions and user consent for delegated permissions.

Microsoft AppSource — Consent Model

Consent Type	Description	Required For
User consent	Individual user grants delegated permissions	Files.ReadWrite (user's own files only)
Admin consent (tenant-wide)	Global Admin grants application-wide permissions	Mail.Read (all mailboxes), Audit logs
Owner consent	Resource owner grants access to specific resources	SharePoint site-level permissions
Publisher verification	Microsoft verifies app publisher identity	Required for all AppSource apps since 2021

Microsoft AppSource OAuth Consent Flow





ServiceNow Store

ServiceNow Store — App Lifecycle

Stage	Implementation
App distribution	ServiceNow Store (HI portal); customer downloads to their instance
User consent	ServiceNow admin activates plugin; no per-user OAuth consent needed
OAuth authorization	IntegrationHub Spokes use OAuth entity profiles per external system
Credential storage	ServiceNow Credential Store (encrypted, vault-like)
Token rotation	OAuth entity profile manages refresh; admin can trigger rotation
Revocation	Admin deactivates plugin or revokes OAuth credentials in Credential Store

Google Workspace Marketplace

Google Workspace Marketplace — App Lifecycle

Stage	Implementation
App distribution	Google Workspace Marketplace; admin installs domain-wide or users self-install
User consent	OAuth 2.0 consent screen; scopes listed explicitly
Admin consent	Domain-wide installation grants access without per-user consent
OAuth flow	Auth code + PKCE for user-level; service account + DWD for domain-wide
Refresh token	Stored by app; Google issues long-lived refresh tokens
Token rotation	Google rotates refresh tokens on sensitive scope use
Revocation	Admin removes app from domain; individual users revoke at myaccount.google.com

AWS Marketplace

AWS Marketplace — Auth Model

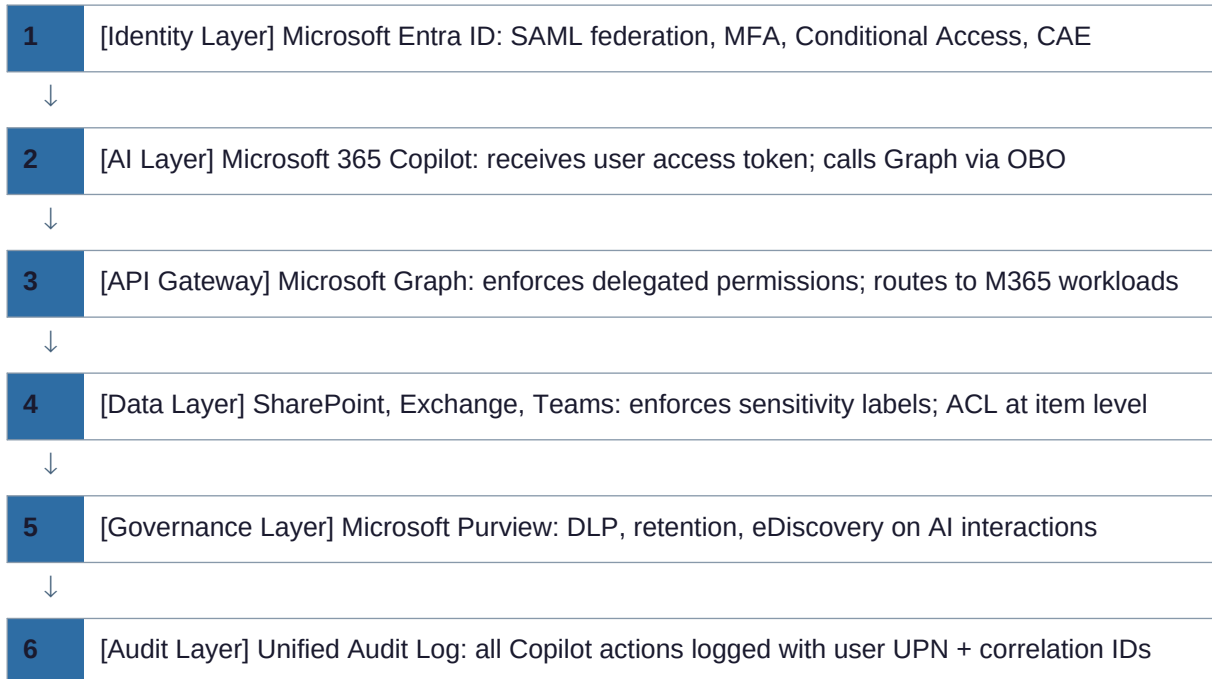
Stage	Implementation
App distribution	AWS Marketplace SaaS listings; customer subscribes via AWS account
Authentication	AWS IAM STS for API access; OIDC for Workload Identity Federation
Authorization	IAM roles with trust policies; resource-based policies per service
Credential model	No long-lived keys — IAM roles, STS AssumeRole, or OIDC provider
Token rotation	STS tokens expire 15 min to 12 hours; auto-refreshed by SDK
Revocation	IAM role revocation; permission boundary removal; SCP at org level

Enterprise Architecture Patterns

Production enterprise AI deployments follow established architecture patterns that separate concerns across identity, data, compute, and governance layers. This section documents the reference patterns used by Microsoft, Google, AWS, Atlassian, and ServiceNow.

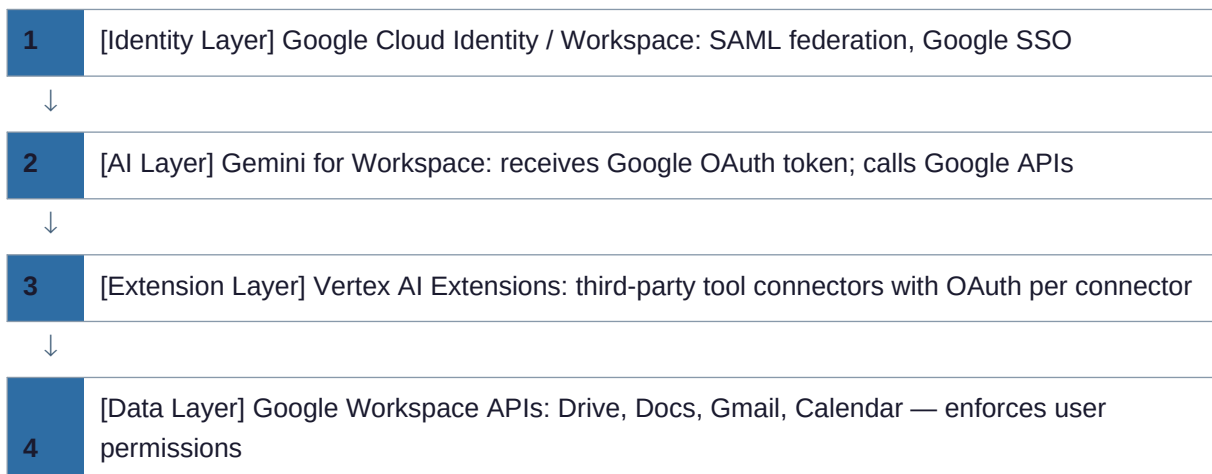
Microsoft Pattern — Copilot + Entra OBO Architecture

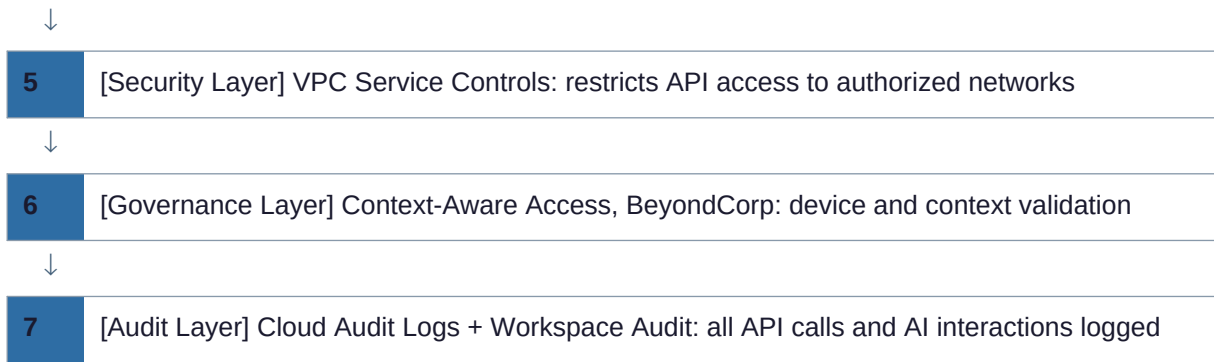
Microsoft M365 Copilot Reference Architecture



Google Pattern — Gemini + Vertex AI Extensions

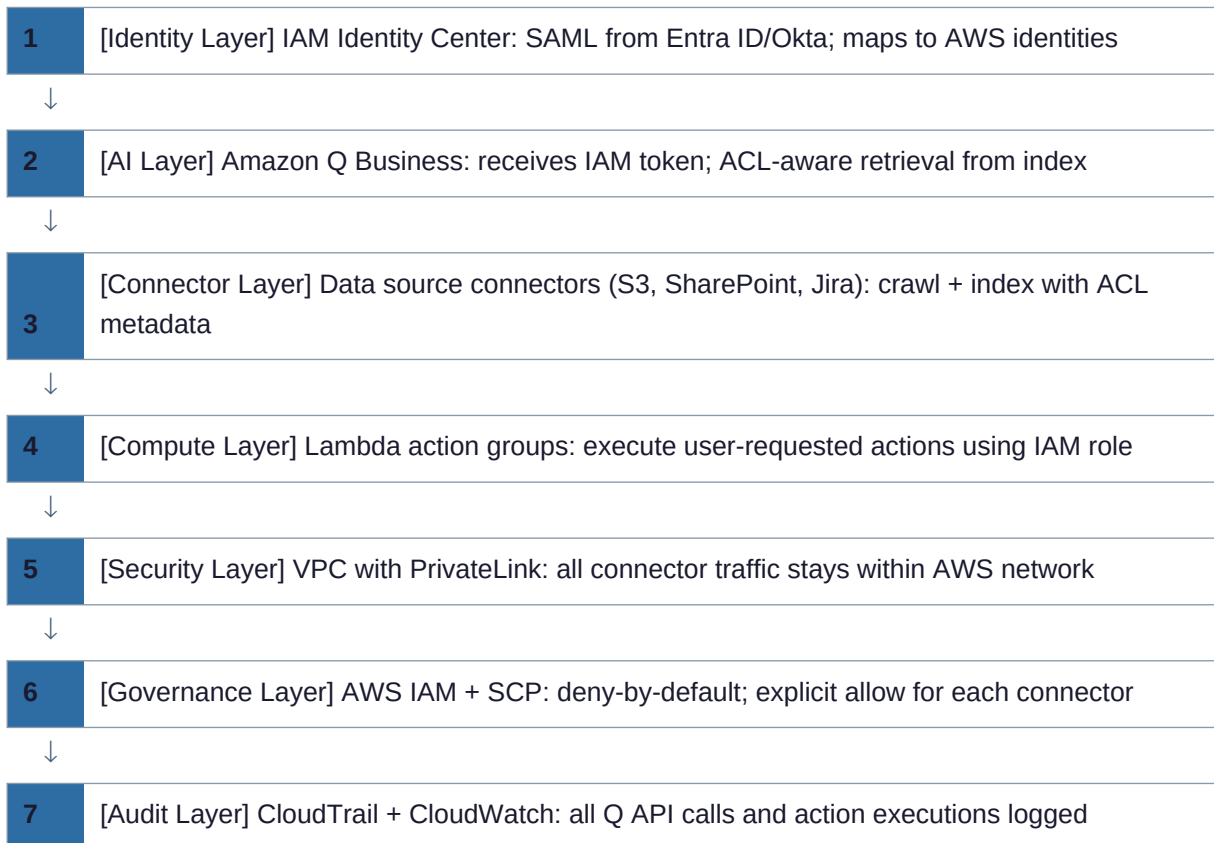
Google Gemini Reference Architecture





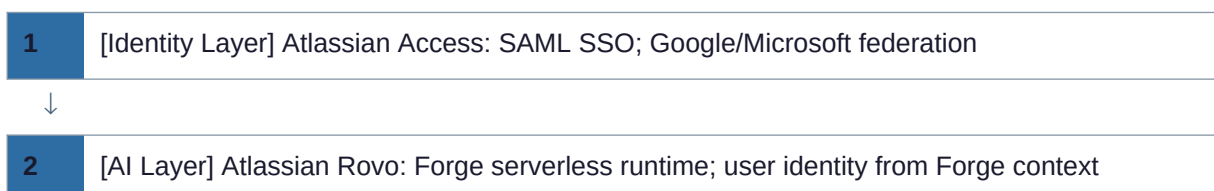
AWS Pattern — Amazon Q Business + IAM Identity Center

AWS Amazon Q Business Reference Architecture



Atlassian Pattern — Rovo + Forge

Atlassian Rovo Reference Architecture





3 [Connector Layer] Forge functions: call Jira/Confluence APIs using user's 3LO OAuth token



4 [External Layer] Third-party connectors: OAuth 2.0 per external service



5 [Security Layer] Atlassian Guard: DLP, shadow IT, audit; IP allowlisting



6 [Audit Layer] Atlassian Audit Log: all Rovo agent actions with user context

Token & Consent Lifecycle Patterns

Initial Consent Lifecycle

Initial Consent & Token Lifecycle

Stage	Actor	Action	Output
Discovery	User	Finds AI tool in marketplace	App identified; scopes reviewed
Admin evaluation	IT Admin	Reviews requested permissions in IdP	Risk assessment completed
Admin pre-consent	Global/Tenant Admin	Grants admin consent for app permissions	Admin consent recorded in IdP
User first use	End User	Opens AI tool; sees consent screen	User consent for delegated scopes
OAuth flow	AI Platform	Completes auth code + PKCE exchange	Access token + refresh token issued
Token storage	AI Platform Backend	Encrypts and stores tokens	Tokens in encrypted database
Session establishment	AI Platform	Creates user session linked to tokens	User can interact with AI

Refresh Token Rotation Lifecycle

Refresh Token Rotation Flow





6 API call retried with new access_token



7 If refresh fails (token revoked): user re-authentication prompt triggered

Revocation Lifecycle

Revocation Scenarios and Latency

Revocation Trigger	What Is Revoked	Effect	Latency
User offboarding (HR)	All refresh tokens for user	All AI sessions terminated; CAE invalidates active tokens	Near-real-time (CAE) or next refresh
Password reset	All refresh tokens	User must re-authenticate everywhere	Immediate (CAE for CAE-capable apps)
Admin policy change	Conditional Access re-evaluation	Active tokens fail CAE check	< 30 seconds (CAE)
Admin removes marketplace app	App's OAuth registration	All tokens for app invalidated	Immediate
User revokes app (self-service)	User's token for specific app	App loses access; user sees confirmation	Immediate
Security incident (admin)	Explicit token revocation via IdP	All sessions for user terminated	Immediate

Token Lifecycle Best Practices Summary

- Access tokens: keep short (60 min); refresh frequently; validate exp claim before each use
- Refresh tokens: store encrypted (AES-256 + KMS); rotate on every use; revoke on sensitive events
- Implement refresh token rotation: each use of refresh token issues a new one; old one is invalidated
- Use CAE-capable resource servers where available to enable real-time revocation
- Audit all token issuances, refreshes, and revocations with correlation to conversation IDs
- Implement token binding where supported (bind token to TLS session) to prevent exfiltration
- Maintain a token revocation list (JTI-based) for high-security contexts